

---

## **O-RAN Work Group 11 (Security Work Group)**

### **Study on Security for Service Management and Orchestration (SMO)**

---

Copyright © 2025 by the O-RAN ALLIANCE e.V. Register of Association, Bonn VR 11238, VAT ID DE321720189

The copying or incorporation into any other work of part or all of the material available in this document in any form without the prior written permission of O-RAN ALLIANCE e.V. is prohibited, save that you may print or download extracts of the material of this document for your personal use, or copy the material of this document for the purpose of sending to individual third parties for their information provided that you acknowledge O-RAN ALLIANCE as the source of the material and that you inform the third party that these conditions apply to them and that they must comply with them.

O-RAN ALLIANCE e.V., Buschkauler Weg 27, 53347 Alfter, Germany  
Register of Associations, Bonn VR 11238, VAT ID DE321720189

---

# Contents

|                                                                 |    |
|-----------------------------------------------------------------|----|
| Foreword.....                                                   | 3  |
| Modal verbs terminology .....                                   | 3  |
| 1 Scope.....                                                    | 4  |
| 2 References.....                                               | 5  |
| 3 Definitions of terms, symbols, and abbreviations.....         | 7  |
| 3.1 Terms.....                                                  | 7  |
| 3.2 Symbols.....                                                | 8  |
| 3.3 Abbreviations .....                                         | 8  |
| 4 SMO Assets .....                                              | 10 |
| 4.1 Architecture.....                                           | 10 |
| 4.2 Functions .....                                             | 14 |
| 4.3 Applications .....                                          | 14 |
| 4.4 Interfaces .....                                            | 14 |
| 4.5 Information.....                                            | 15 |
| 4.6 SMO Services (SMOS) .....                                   | 16 |
| 5 Threats.....                                                  | 17 |
| 5.1 Threat Model .....                                          | 17 |
| 5.2 Threat Template .....                                       | 17 |
| 5.3 Potential Threats and Exploits .....                        | 18 |
| 5.4 SMO Threats .....                                           | 18 |
| 6 Threat Analysis .....                                         | 20 |
| 6.1 General SMO Threats.....                                    | 20 |
| 6.2 Threats at O2 interface .....                               | 24 |
| 6.3 Threats at External interfaces.....                         | 26 |
| 6.4 Threats Targeting SME .....                                 | 27 |
| 6.5 Preliminary Threat Analysis for RAN-Core Data Sharing ..... | 28 |
| 6.6 Threats Targeting DME .....                                 | 29 |
| 7 Security Controls.....                                        | 30 |
| 8 Risk Assessment .....                                         | 32 |
| 8.1 General SMO Risks.....                                      | 32 |
| 8.2 Threats at O2 interface .....                               | 33 |
| 8.3 Threats at External Interfaces.....                         | 34 |
| 8.4 Threats Targeting SME .....                                 | 35 |
| 9 Primary Security Issues.....                                  | 36 |
| 10 Recommendations.....                                         | 37 |
| Annex: Change history/Change request (history) .....            | 39 |

# Foreword

This Technical Report (TR) has been produced by WG11 of the O-RAN ALLIANCE.

The content of the present document is subject to continuing work within O-RAN and may change following formal O-RAN approval. Should the O-RAN ALLIANCE modify the contents of the present document, it will be re-released by O-RAN with an identifying change of version date and an increase in version number as follows:

version xx.yy.zz

where:

xx: the first digit-group is incremented for all changes of substance, i.e. technical enhancements, corrections, updates, etc. (the initial approved document will have xx=01). Always 2 digits with leading zero if needed.

yy: the second digit-group is incremented when editorial only changes have been incorporated in the document. Always 2 digits with leading zero if needed.

zz: the third digit-group included only in working versions of the document indicating incremental changes during the editing process. External versions never include the third digit-group. Always 2 digits with leading zero if needed.

## Modal verbs terminology

In the present document "**shall**", "**shall not**", "**should**", "**should not**", "**may**", "**need not**", "**will**", "**will not**", "**can**" and "**cannot**" are to be interpreted as described in clause 3.2 of the O-RAN Drafting Rules (Verbal forms for the expression of provisions).

"**must**" and "**must not**" are **NOT** allowed in O-RAN deliverables except when used in direct citation.

# 1 Scope

This technical report provides the threat model and risk assessment for the SMO. The report identifies threats and risks and recommends potential security controls to protect against those threats through safeguards or mitigation.

The steps of the threat modelling process are as follows:

1. Identify assets: Identify the assets of the SMO that must be protected.
2. Identify threats: Identify the threats that could adversely impact the SMO and threats that can use the SMO to adversely impact other components of the O-RAN system.
3. Identify the attack surface and attack vectors: Identify the points in the SMO where an attacker could
  - a. gain entry to the SMO
  - b. gain entry to another O-RAN system through the SMO
  - c. exploit a vulnerability or misconfiguration
  - d. compromise the system or its data.
4. Measure risk: The extent to which confidentiality, integrity, or availability is threatened, based upon a risk-based analysis considering the impact level resulting from an attack and the likelihood of occurrence.
5. Recommend controls: The management, operational, and technical controls for an information system to protect the confidentiality, integrity and availability of the SMO and its information.

This Technical Report makes the following considerations:

- The attack surface of the SMO includes its interfaces, functions, and data. Data-at-rest, Data-in-motion, and Data-in-use must be considered.
- O-RAN Alliance WG1 is in the process of defining an architecture for a decoupled SMO. This will influence the set of assets to be protected.
- The O-RAN Alliance is pursuing a zero-trust architecture (ZTA) for its specifications based upon NIST SP 800-207 [i.8]. This will affect the risk scoring.
- Security controls are recommended for specifications of the SMO. The recommended controls provided in this report will be shared with the responsible O-RAN Alliance working group, such as WG1 and WG10, so that the appropriate specification relevant to the recommendation can be updated.
- Some of the identified SMO assets may already be in scope for separate ongoing WG11 security work items. The SMO security Technical Report work item may inform those work items.

## 2 References

### 2.1 Normative references

Not applicable.

### 2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies. In the case of a reference to a 3GPP document, a non-specific reference implicitly refers to the latest version of that document in Release 18, or the latest 3GPP release prior to Release 18 that includes that document.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, O-RAN cannot guarantee their long-term validity.

The following referenced documents are not necessary for the application of the present document, but they assist the user with regard to a particular subject area.

- [i.1] O-RAN ALLIANCE PD: "O-RAN Document Drafting Rules (ODR)".
- [i.2] O-RAN ALLIANCE TS: "O-RAN Architecture Description (OAD)".
- [i.3] O-RAN ALLIANCE TS: "O-RAN Non-Real-Time RAN Intelligent Controller".
- [i.4] O-RAN ALLIANCE TS: "O-RAN Security Protocols Specifications".
- [i.5] O-RAN ALLIANCE TS: "O-RAN Security Requirements and Controls Specifications".
- [i.6] O-RAN ALLIANCE TR: "O-RAN Threat Modelling and Risk Assessment".
- [i.7] O-RAN ALLIANCE TS: "O-RAN Security Test Specifications".
- [i.8] Zero Trust Architecture, NIST SP 800-207, NIST, August 2020, <https://csrc.nist.gov/publications/detail/sp/800-207/final>.
- [i.9] US National Security Agency (NSA) / Cybersecurity and Infrastructure Security Agency (CISA), Security Guidance for 5G Cloud Infrastructures, Part I, Oct 28, 2021, Part II, Nov 18, 2021, Part III, Dec 2, 2021, Part IV, Dec 16, 2021. <https://www.nsa.gov/Press-Room/Cybersecurity-Advisories-Guidance/smdpage11747/2/> (as of Feb 28, 2022).
- [i.10] Not used.
- [i.11] Not used.
- [i.12] OWASP Top 10 Web Application Security Risks, 2021, <https://owasp.org/www-project-top-ten/>.
- [i.13] Cloud Security Alliance (CSA), Top Threats to Cloud Computing: Egregious Eleven, 2019, <https://cloudsecurityalliance.org/artifacts/top-threats-to-cloud-computing-egregious-eleven>.
- [i.14] Cloud Security Alliance (CSA), Top Threats to Cloud Computing: Pandemic Eleven, 2022, <https://cloudsecurityalliance.org/artifacts/top-threats-to-cloud-computing-pandemic-eleven>.
- [i.15] OWASP Top 10 Proactive Controls, 2021, <https://owasp.org/projects/spotlight/historical/2021.02.10/>
- [i.16] Center for Internet Security (CIS) Critical Security Controls, <https://www.cisecurity.org/controls/cis-controls-list>
- [i.17] Cloud Security Alliance (CSA) Cloud Control Matrix (CCM), <https://cloudsecurityalliance.org/research/cloud-controls-matrix/>
- [i.18] ISO/IEC 27001:2013 Information Security Management System (ISMS).

- [i.19] NIST SP 800-53r5, Security and Privacy Controls for Information Systems and Organizations, 2020.
- [i.20] O-RAN ALLIANCE TR: Study on Security for Non-RT-RIC
- [i.21] O-RAN ALLIANCE TR: Decoupled SMO Architecture
- [i.22] 3GPP TR 21.905: "Vocabulary for 3GPP Specifications", Release 18.

## 3 Definitions of terms, symbols, and abbreviations

### 3.1 Terms

This document uses the verbal forms for the expression of provisions as defined in O-RAN Document Drafting Rules (ODR) [i.1]

This document uses the term Zero Trust Architecture (ZTA) as defined by US NIST in [i.8] and applied to 5G cloud deployments by US CISA in [i.9].

A ZTA provides protection from external and internal threats, assuming the following:

1. there is no implicit trust granted to an asset based upon ownership, physical location, or network location [i.8]
2. the adversary is already inside the network. Perimeter defenses are no longer sufficient to secure a network, and there should always be an assumption that a threat actor has established a foothold in the network [i.9]

This document uses the term “attack surface” defined by US NIST as

*The set of points on the boundary of a system, a system element, or an environment where an attacker can try to enter, cause an effect on, or extract data from, that system, system element, or environment*  
[[https://csrc.nist.gov/glossary/term/attack\\_surface](https://csrc.nist.gov/glossary/term/attack_surface)]

This document refers to “sensitive information” defined by US NIST as

*information whose loss, misuse, or unauthorized access or modification could adversely affect security*  
[<https://csrc.nist.gov/glossary/term/sensitive>]

For the purposes of the present document, the terms and definitions provided in [i.2] apply:

**A1 Interface:** Interface between Non-RT RIC and Near-RT RIC to enable policy-driven guidance of Near-RT RIC applications/functions, and support AI/ML workflow.

**External Interface:** The interface between the SMO and an External System.

**External System:** A digital entity outside the O-RAN domain that is a consumer or producer for SMO Services.

**Near-RT RIC:** O-RAN Near-Real-Time RAN Intelligent Controller: A logical function that enables near-real-time control and optimization of RAN elements and resources via fine-grained data collection and actions over E2 interface. It may include AI/ML (Artificial Intelligence / Machine Learning) workflow including model training, inference and updates.

**Non-RT RIC:** O-RAN Non-Real-Time RAN Intelligent Controller: A logical function within SMO that drives the content carried across the A1 interface. It is comprised of the Non-RT RIC Framework and the Non-RT RIC Applications (rApps) whose functions are defined below.

**Non-RT RIC Applications (rApps):** Modular applications that leverage the functionality exposed via the Non-RT RIC Framework’s R1 interface to provide added value services relative to RAN operation, such as driving the A1 interface, recommending values and actions that may be subsequently applied over the O1/O2 interface and generating “enrichment information” for the use of other rApps. The rApp functionality within the Non-RT RIC enables non-real-time control and optimization of RAN elements and resources and policy-based guidance to the applications/features in Near-RT RIC.

**Non-RT RIC Framework:** That functionality internal to the SMO that logically terminates the A1 interface to the Near-RT RIC and exposes to rApps, via its R1 interface, the set of internal SMO services needed for their runtime processing. The Non-RT RIC Framework functionality within the Non-RT RIC provides AI/ML workflow including model training, inference and updates needed for rApps.

**R1 Interface:** Interface between rApps and Non-RT RIC Framework via which R1 Services can be produced and consumed.

**R1 Services:** A collection of services including, but not limited to, service registration and discovery services, authentication and authorization services, AI/ML workflow services, and A1, O1 and O2 related services.

**Service Management and Exposure (SME):** A SMOS which enables services applicable to any entities within the SMO that fulfil the roles of SMO Service Producer and/or SMO Service Consumer.

**Service Management and Orchestration (SMO):** The O-RAN Service Management and Orchestration system as specified in the O-RAN Architecture Description (OAD) document [i.2], Clause 5.3.1.

**Service Management and Orchestration Function (SMOF):** Internal SMO entities which provide one or more SMO Services.

**Service Management and Orchestration Service (SMOS):** Set of management, orchestration and automation capabilities offered by a SMO Function.

**SMOS Communication:** Communication support between SMOS Producers and SMOS Consumers.

## 3.2 Symbols

None

## 3.3 Abbreviations

For the purposes of the present document, the abbreviations given in 3GPP TR 21.905 [i.22] and the following apply:

|       |                                                |
|-------|------------------------------------------------|
| ABAC  | Attribute Based Access Control                 |
| AI    | Artificial Intelligence                        |
| CM    | Configuration Management                       |
| DAR   | Data at Rest                                   |
| DIM   | Data in Motion                                 |
| DIU   | Data in Use                                    |
| DME   | Data Management and Exposure                   |
| EI    | Enrichment Information                         |
| eNB   | eNodeB (applies to LTE)                        |
| FM    | Fault Management                               |
| FOCOM | Federated O-Cloud Orchestration and Management |
| FTP   | File Transfer Protocol                         |
| FTPS  | File Transfer Protocol Secure                  |
| gNB   | gNodeB (applies to NR)                         |
| HTTP  | Hypertext Transfer Protocol                    |

|       |                                             |
|-------|---------------------------------------------|
| HTTPS | Hypertext Transfer Protocol Secure          |
| JSON  | JavaScript Object Notation                  |
| KPI   | Key Performance Indicator                   |
| KQI   | Key Quality Indicator                       |
| ML    | Machine Learning                            |
| MNO   | Mobile Network Operator                     |
| NF    | Network Function                            |
| NFO   | Network Function Orchestrator               |
| OWASP | Open Worldwide Application Security Project |
| PBAC  | Policy Based Access Control                 |
| PII   | Personally Identifiable Information         |
| PKI   | Public Key Infrastructure                   |
| PM    | Performance Management                      |
| PTP   | Precision Timing Protocol                   |
| RBAC  | Role-based Access Control                   |
| REST  | Representational State Transfer             |
| RIC   | RAN Intelligent Controller                  |
| RT    | Real-Time                                   |
| SBA   | Service-Based Architecture                  |
| SME   | Service Management and Exposure             |
| SMO   | Service Management and Orchestration        |
| SMOF  | SMO Functions                               |
| SMOS  | SMO Services                                |
| SSH   | Secure Shell                                |
| TBAC  | Task Based Access Control                   |
| TCP   | Transmission Control Protocol               |
| TE&IE | Topology Exposure and Inventory Management  |
| TLS   | Transport Layer Security                    |
| ZTA   | Zero Trust Architecture                     |

## 4 SMO Assets

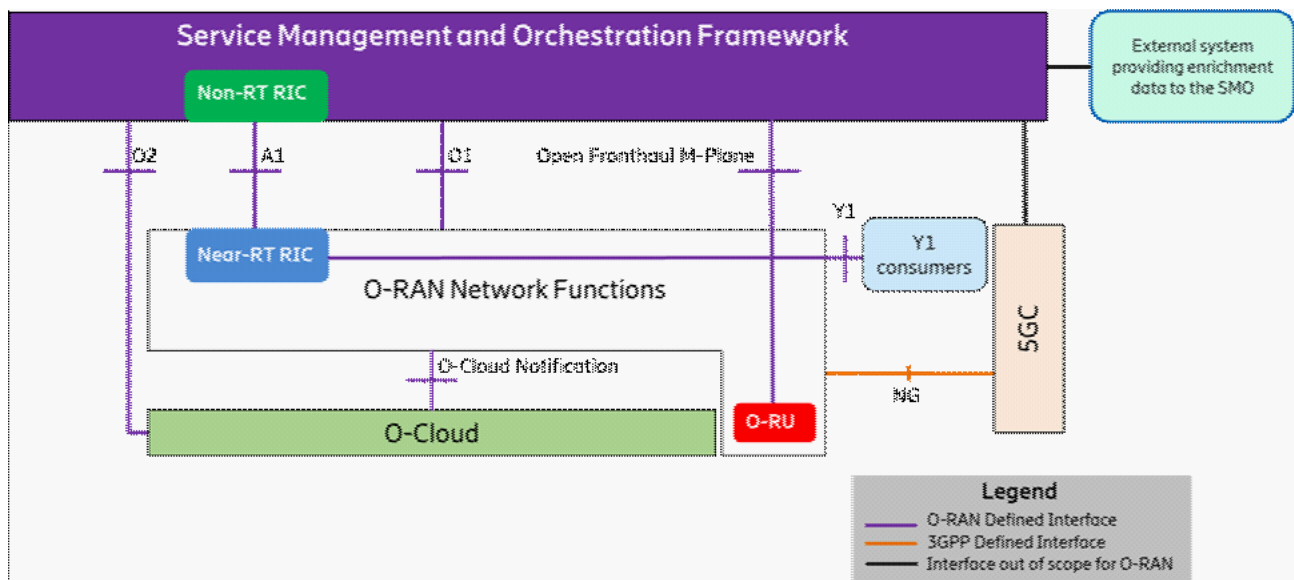
### 4.1 Architecture

There are security risks with the SMO due to its internal functions and internal and external interfaces. Securing the SMO is imperative because it is responsible for all service management and orchestration. A security vulnerability within the SMO could be exploited to serve as an entry point for attacks against O-RAN components and lateral movement across O-RAN.

Figure 4.1-1 and Figure 4.1-2 show the service-based architectural view of the SMO including internal and external interfaces and the Non-RT-RIC. The Attack Surface of the SMO includes Functions, Applications, Interfaces, and Information, which each have assets that should be protected. Figure 4.1-3 is the SMO security architecture, based upon Figures 4.1-1 and 4.1-2. Figure 4.1-4 shows the evolution of the SMO to a Service-Based Architecture, and Figure 4.1-5 is the Decoupled SMO security architecture with support for RAN-Core Data Sharing. The following SMO assets need to be protected:

- SMO Framework
- SMO Functions (SMOF)
- Non-RT RIC
- SMO Services (SMOS)
  - Service Management and Exposure (SME)
  - Data Management and Exposure (DME)
  - Topology Exposure and Inventory Management (TE&IM)
  - rApp Management
  - R1 Services
  - Network Function Orchestrator (NFO)
  - Federated O-Cloud Orchestration and Management (FOCOM)
  - RAN NF Fault Management (FM)
  - RAN NF Configuration Management (CM)
  - RAN NF Performance Management (PM)
  - A1 Enrichment Information Management
  - A1 Policy Management
  - SW Package Onboarding
  - Service Orchestration
  - Service Assurance
  - RAN Analytics

- AI/ML Workflow
  - SMOS Communication
  - O1, O2, R1 and A1 interfaces
  - Open Fronthaul M-Plane
  - External interfaces
  - User Management interfaces
  - PKI
  - Logging
  - Data
  - AI/ML models, algorithms, and methods



**Figure 4.1-1. High-Level Architecture of O-RAN [i.2]**

Figure 4.1-2 shows the Non-RT RIC architectural view with its SMO integration.

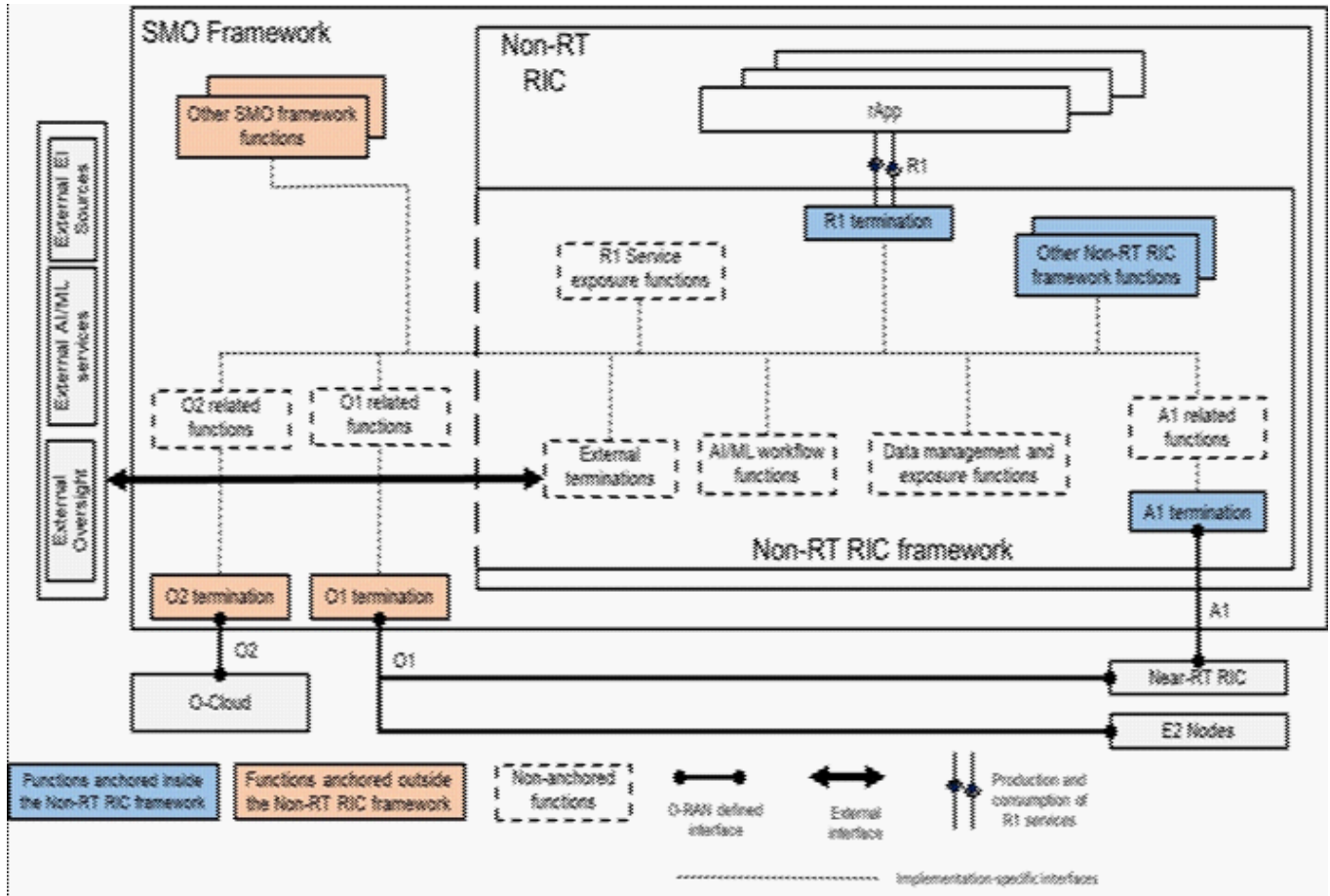


Figure 4.1-2. Non-RT-RIC Reference Architecture [i.3]

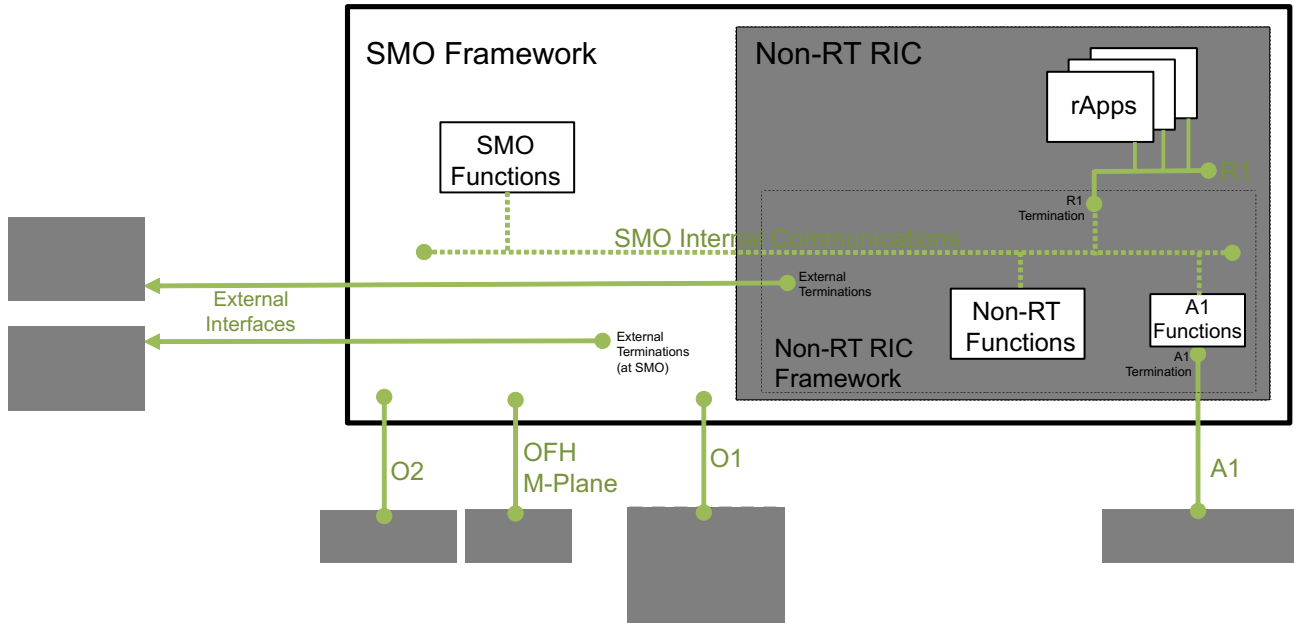


Figure 4.1-3. SMO Security Architecture

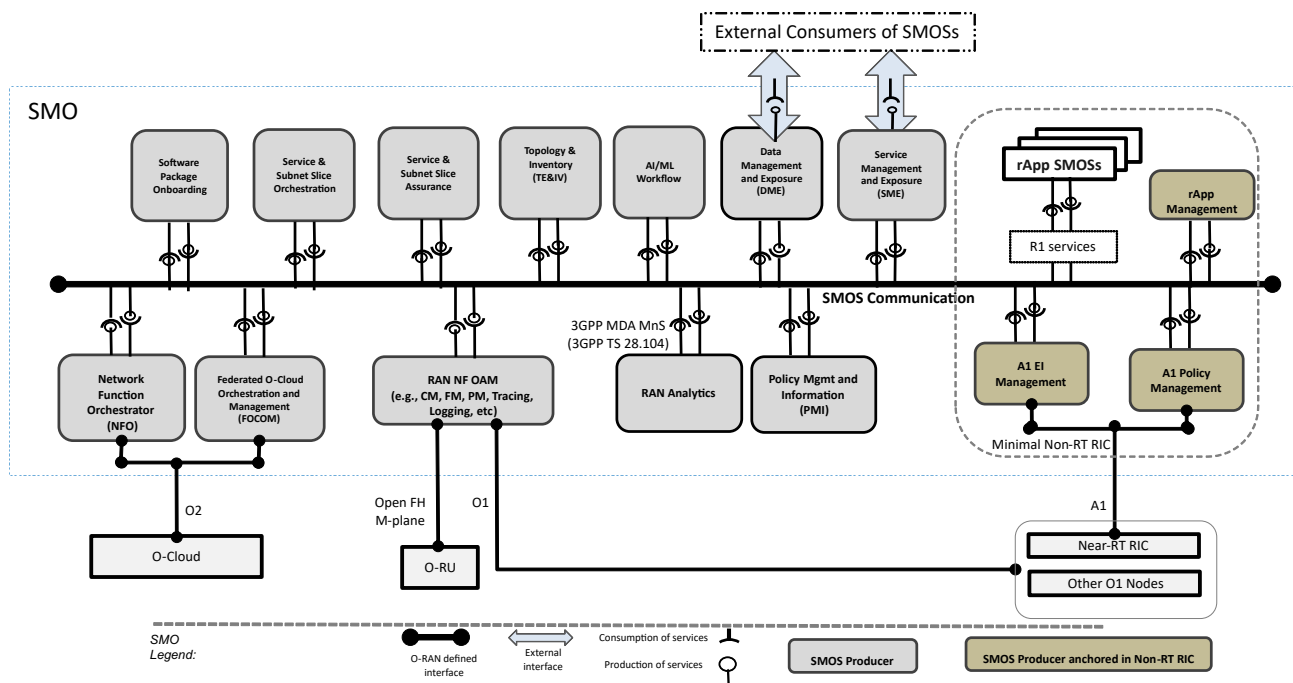


Figure 4.1-4. Decoupled SMO with SBA [i.21]

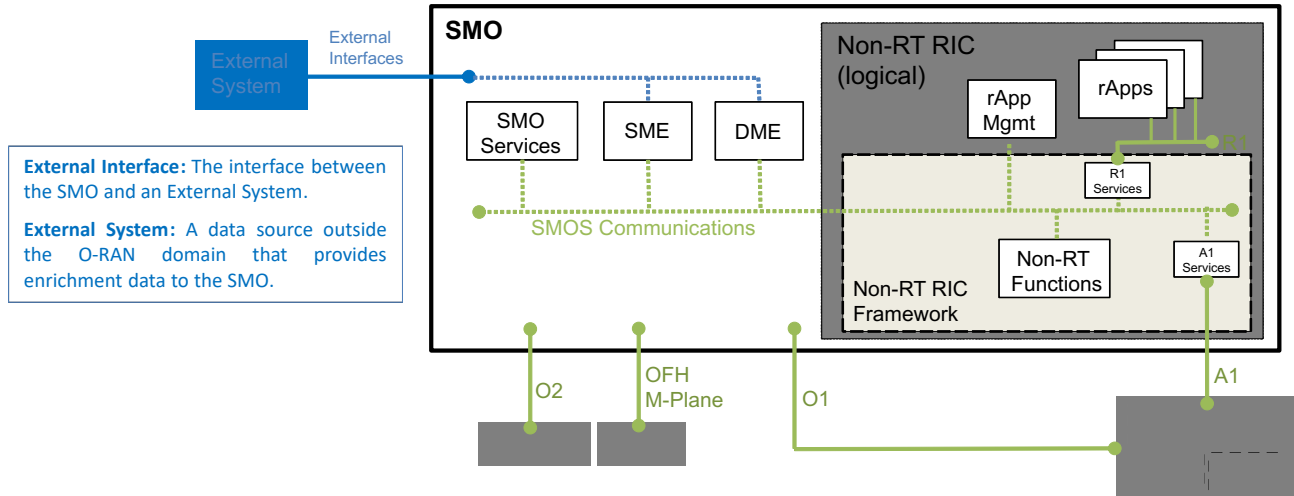


Figure 4.1-5. Decoupled SMO Security Architecture

## 4.2 Functions

The following SMO functions should be considered in a risk analysis:

- ASSET-C-01: SMO Framework
- ASSET-C-11: Non-RT RIC
- ASSET-C-18: SMO Functions
- Non-RT Functions, including:
  - ASSET-C-12: AI/ML Functions
- ASSET-C-20: A1 Functions

## 4.3 Applications

The following SMO applications should be considered in a risk analysis:

- ASSET-C-10: rApps

## 4.4 Interfaces

The following SMO interfaces should be considered in a risk analysis:

- ASSET-C-14: A1
- ASSET-C-16: R1
- ASSET-C-26: External Interfaces

- ASSET-C-22: O1
- ASSET-C-23: O2
- ASSET-C-24: OFH M-Plane
- ASSET-C-62: SMOS Communication

## 4.5 Information

The following SMO information and data should be considered in a risk analysis:

- O1 Data
  - ASSET-D-03: O1 Critical management plane data
  - ASSET-D-09: O1 informational data
- O2 Data
  - ASSET-D-12: O2-IMS and O2-DMS data
  - ASSET-D-13: O2 Telemetry data
  - ASSET-D-14: O2 cloud provisioning data
- Secret Stores
  - ASSET-D-16: X.509 certificates
  - ASSET-D-17: Private keys
  - ASSET-D-20: Administrator credentials (passwords and tokens)
- AI/ML Data
  - ASSET-D-25: Training or test data: data sets collected externally or internally from the Near-RT RIC, O-CU and O-DU and passed to the ML training hosts in a ML system.
  - ASSET-D-26: The trained ML model which includes intellectual property, numerous configured hyperparameters and millions of learned parameters.
  - ASSET-D-27: The ML prediction results built into the model (e.g. expected outcomes)
  - ASSET-D-28: The behavior of the ML system including tasks for data collection, data wrangling, pipeline management, model retraining, and model deployment.
- PII
  - ASSET-D-30: O-RAN specific UE IDs
- Event logs
  - ASSET-D-29: Security event log files generated by O-RAN components

## 4.6 SMO Services (SMOS)

The following SMO Services should be considered in a risk analysis:

- ASSET-C-44: Service Management and Exposure (SME)
- ASSET-C-45: Data Management and Exposure (DME)
- ASSET-C-46: Topology Exposure and Inventory Management (TE&IM)
- ASSET-C-47: rApp Management
- ASSET-C-48: R1 Services
- ASSET-C-49: Network Function Orchestrator (NFO)
- ASSET-C-50: Federated O-Cloud Orchestration and Management (FOCOM)
- ASSET-C-51: RAN NF Fault Management (FM)
- ASSET-C-52: RAN NF Configuration Management (CM)
- ASSET-C-53: RAN NF Performance Management (PM)
- ASSET-C-54: A1 Enrichment Information Management
- ASSET-C-55: A1 Policy Management
- ASSET-C-57: SW Package Onboarding
- ASSET-C-58: Service Orchestration
- ASSET-C-59: Service Assurance
- ASSET-C-60: RAN Analytics
- ASSET-C-61: AI/ML Workflow

---

## 5 Threats

### 5.1 Threat Model

For identifying threats, we are using STRIDE:

1. S - Spoofing identity. A user, application or program can masquerade as another to gain advantages not typically allowed for that user, application, or program.
2. T - Tampering with data. This involves the malicious modification of data, including making unauthorized changes to a database and alteration of data as it flows between computers.
3. R - Repudiation. A user or program refuses the authenticity of a good or reasonable command or action.
4. I - Information disclosure. This involves the exposure of information to individuals with unauthorized access to it. For example, users gain the ability to read a file that they normally would not have been granted access to, or an intruder can read data in transit between computers.
5. D - Denial of service. These attacks deny service to valid users, such as making a website unavailable or unusable by flooding it with illegitimate requests to keep legitimate users without access.
6. E - Elevation of privileges. An unauthorized user gains privileged rights to access previously no granted to compromise or destroy the system, such as a change in membership.

| Threat types           | Impact types    |
|------------------------|-----------------|
| Spoofing               | Authenticity    |
| Tampering              | Integrity       |
| Repudiation            | Non-repudiation |
| Information disclosure | Confidentiality |
| Denial of Service      | Availability    |
| Elevation of Privilege | Authorization   |

### 5.2 Threat Template

Template to present the threat characteristics:

|                           |                                                                                                               |
|---------------------------|---------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          |                                                                                                               |
| <b>Threat title</b>       |                                                                                                               |
| <b>Threat description</b> |                                                                                                               |
| <b>Threat type</b>        | Spoofing<br>Tampering<br>Repudiation<br>Information disclosure<br>Denial of Service<br>Elevation of Privilege |
| <b>Vulnerabilities</b>    |                                                                                                               |
| <b>Impact type</b>        | Authenticity<br>Integrity<br>Non-repudiation<br>Confidentiality<br>Availability<br>Authorization              |
| <b>Affected Assets</b>    |                                                                                                               |

## 5.3 Potential Threats and Exploits

A threat analysis is facilitated by an understanding of potential threats, as identified by the Cloud Security Alliance (CSA) and the Open Web Application Security Project (OWASP).

The OWASP Top 10 Web Application Security Risks [i.12] was updated in 2021 to include the following:

- A01:2021 Broken Access Control
- A02:2021 Cryptographic Failure
- A03:2021 Injection (including Cross-Site Scripting)
- A04:2021 Insecure Design
- A05:2021 Security Misconfiguration
- A06:2021 Vulnerable and Outdated Components
- A07:2021 Identification and Authentication Failures
- A08:2021 Software and Data Integrity Failures (including Insecure Deserialization)
- A09:2021 Security Logging and Monitoring Failures
- A10:2021 Server-Side Request Forgery

The CSA Top Threats to Cloud in 2019 was labelled the “Egregious Eleven” [i.13], as listed below:

1. Data Breaches
2. Misconfiguration and Inadequate Change Control
3. Lack of Cloud Security Architecture and Strategy
4. Insufficient Identity, Credential, Access, and Key Management
5. Account Hijacking
6. Insider Threat
7. Insecure Interfaces and APIs
8. Weak Control plane
9. Metastructure and Applistructure Failures
10. Limited Cloud Usage Visibility
11. Abuse and Nefarious Uses of Cloud Services

The CSA updated its list of top threats to cloud in 2022 and renamed it the “Pandemic Eleven” [i.14], as listed below:

1. Insufficient Identity, Credential, Access and Key Management, Privileged Accounts
2. Insecure Interfaces and APIs
3. Misconfiguration and Inadequate Change Control
4. Lack of Cloud Security Architecture and Strategy
5. Insecure Software Development
6. Unsecure Third-Party Resources
7. System Vulnerabilities
8. Accidental Cloud Data Disclosure
9. Misconfiguration and Exploitation of Serverless and Container Workloads
10. Organized Crime, Hackers & APT
11. Cloud Storage Data Exfiltration

## 5.4 SMO Threats

The threats listed in clause 5.3 relevant to O-RAN and SMO are considered in the SMO threat analysis. The threats to SMO shown in Table 5.4.1 have been identified and are analyzed in clause 6 – Threat Analysis.

Table 5.4.1 – SMO Threats Summary

| Threat-Id                             | Threat Description (Brief)                                                                                        |
|---------------------------------------|-------------------------------------------------------------------------------------------------------------------|
| <b>General SMO Threats</b>            |                                                                                                                   |
| T-SMO-01                              | External attacker exploits authentication weakness on SMO                                                         |
| T-SMO-02                              | External attacker exploits authorization weakness on SMO                                                          |
| T-SMO-03                              | External Overload DoS attack targeted at SMO                                                                      |
| T-SMO-04                              | Internal attacker exploits authentication weakness on a SMO function or SMO service                               |
| T-SMO-05                              | Internal attacker exploits authorization weakness on SMO                                                          |
| T-SMO-06                              | Internal Overload DoS attack targeted at SMO functions or SMO services                                            |
| T-SMO-07                              | Internal DoS attack disables internal SMO function(s), SMO service(s), or SMO process(es)                         |
| T-SMO-08                              | Attacker exploits insecure API to gain access to SMO                                                              |
| T-SMO-09                              | Sensitive data in motion is exposed to an internal attacker                                                       |
| T-SMO-10                              | Sensitive data at rest is exposed to an internal attacker                                                         |
| T-SMO-11                              | AI/ML poisoning by internal attacker                                                                              |
| T-SMO-12                              | AI/ML exposure on external entity                                                                                 |
| T-SMO-13                              | Malicious actor views local logs                                                                                  |
| T-SMO-14                              | Malicious actor modifies local log entries                                                                        |
| T-SMO-15                              | Malicious actor deletes local logs                                                                                |
| T-SMO-16                              | Malicious actor intercepts exports of local logs                                                                  |
| T-SMO-17                              | Malicious external actor gains unauthorized access to logs                                                        |
| T-SMO-18                              | Malicious internal actor gains authorized access to logs                                                          |
| <b>Threats at O2 interface</b>        |                                                                                                                   |
| T-SMO-19                              | Internal attacker exploits O2 interface to view data in transit between SMO and O-Cloud                           |
| T-SMO-20                              | Internal attacker exploits O2 interface to modify data in transit between SMO and O-Cloud                         |
| T-SMO-21                              | Internal attacker uses O2 interface via SMO to exploit API vulnerability to gain access to O-Cloud infrastructure |
| T-SMO-22                              | Internal attacker floods O2 interface via SMO to cause DDoS on O-Cloud infrastructure                             |
| T-SMO-23                              | External attacker uses O2 interface via O-Cloud to exploit API vulnerability to gain access to SMO                |
| T-SMO-24                              | External attacker floods O2 interface via O-Cloud to cause DDoS on SMO                                            |
| T-SMO-25                              | External attacker uses O2 interface via O-Cloud to gain authorized access to sensitive data-at-rest at the SMO    |
| <b>Threats at External interfaces</b> |                                                                                                                   |
| T-SMO-26                              | External attacker exploits External interface to view data in transit between SMO and external service            |
| T-SMO-27                              | External attacker exploits External interface to modify data in transit between SMO and external service          |
| T-SMO-28                              | External attacker uses External interface to exploit API vulnerability to gain access to SMO                      |
| T-SMO-29                              | External attacker floods External interface to cause DDoS at SMO                                                  |
| T-SMO-30                              | External attacker uses External interface to gain access to sensitive data-at-rest at the SMO                     |
| T-SMO-31                              | External attacker poisons External AI/ML data to corrupt SMO                                                      |
| T-SMO-32                              | External attacker poisons External Enrichment Information data sources to corrupt SMO                             |
| T-SMO-33                              | rApp floods SME                                                                                                   |
| T-SMO-34                              | External Consumer floods SME                                                                                      |
| T-SMO-35                              | SMOS flood SME                                                                                                    |
| T-SMO-36                              | rApp floods DME                                                                                                   |
| T-SMO-37                              | External Consumer floods DME                                                                                      |
| T-SMO-38                              | SMOS flood DME                                                                                                    |

## 6 Threat Analysis

SMO threats are identified in the tables below. External and internal threats are from the perspective of the SMO. External Threats are external to the SMO and Internal Threats are internal the SMO. This section provides threat analysis of four types of SMO threats:

- General SMO Threats
- Threats at O2 interface
- Threats at External interfaces
- Threats targeting SME
- Threats targeting DME

### 6.1 General SMO Threats

|                           |                                                                                                                                                                                                                                                                                                                                               |
|---------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-01                                                                                                                                                                                                                                                                                                                                      |
| <b>Threat title</b>       | External attacker exploits authentication weakness on SMO                                                                                                                                                                                                                                                                                     |
| <b>Threat description</b> | An external attacker can exploit the improper/missing authentication weakness on SMO functions or SMO services. If the authentication of O-RAN subjects on A1, O1, O2, and External interfaces on SMO is not supported or not properly implemented, those interfaces without proper credentials could be exploited to gain access to the SMO. |
| <b>Threat type</b>        | Spoofing                                                                                                                                                                                                                                                                                                                                      |
| <b>Impact type</b>        | Authenticity                                                                                                                                                                                                                                                                                                                                  |
| <b>Affected Asset</b>     | SMO                                                                                                                                                                                                                                                                                                                                           |

|                           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|---------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-02                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| <b>Threat title</b>       | External attacker exploits authorization weakness on SMO                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| <b>Threat description</b> | An external attacker can exploit the improper/missing authorization weakness on SMO functions or SMO services. A malicious external entity on A1, O1, O2, and External interfaces without authorization or with an incorrect access token may invoke the SMO functions or SMO services. The data at rest related to that function will be leaked to the attacker. In addition, an attacker can be able to perform certain actions, e.g. disclose O-RAN sensitive information or alter O-RAN components. |
| <b>Threat type</b>        | Elevation of Privilege, Information Disclosure                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| <b>Impact type</b>        | Authorization. Confidentiality                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| <b>Affected Asset</b>     | SMO                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |

|                           |                                                                                                                                                                                                                                                           |
|---------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-03                                                                                                                                                                                                                                                  |
| <b>Threat title</b>       | External Overload DoS attack targeted at SMO                                                                                                                                                                                                              |
| <b>Threat description</b> | Overload situation could appear in the case of DoS attack or increased traffic on externally facing interfaces. Inability to mitigate traffic volumetric attacks on an external interface affects availability of SMO data and functions or SMO services. |
| <b>Threat type</b>        | Denial of Service                                                                                                                                                                                                                                         |

|                       |              |
|-----------------------|--------------|
| <b>Impact type</b>    | Availability |
| <b>Affected Asset</b> | SMO          |

|                           |                                                                                                                                                                                                                                                                                                      |
|---------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-04                                                                                                                                                                                                                                                                                             |
| <b>Threat title</b>       | Internal attacker exploits authentication weakness on a SMO function or SMO service                                                                                                                                                                                                                  |
| <b>Threat description</b> | An internal attacker can exploit the improper/missing authentication weakness on SMO functions or SMO services. If the authentication of internal interfaces on SMO is not supported or not properly implemented, those interfaces without credentials could be exploited to gain access to the SMO. |
| <b>Threat type</b>        | Spoofing                                                                                                                                                                                                                                                                                             |
| <b>Impact type</b>        | Authenticity                                                                                                                                                                                                                                                                                         |
| <b>Affected Asset</b>     | SMO                                                                                                                                                                                                                                                                                                  |

|                           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|---------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-05                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| <b>Threat title</b>       | Internal attacker exploits authorization weakness on SMO                                                                                                                                                                                                                                                                                                                                                                                                           |
| <b>Threat description</b> | An internal attacker can exploit the improper/missing authorization weakness on SMO functions or SMO services. Malicious internal entities without authorization or with an incorrect access token may invoke the SMO functions or SMO services. The data at rest related to these functions will be leaked to the attacker. In addition, an attacker can be able to perform certain actions, e.g. disclose O-RAN sensitive information or alter O-RAN components. |
| <b>Threat type</b>        | Elevation of Privilege, Information Disclosure                                                                                                                                                                                                                                                                                                                                                                                                                     |
| <b>Impact type</b>        | Authorization                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| <b>Affected Asset</b>     | SMO                                                                                                                                                                                                                                                                                                                                                                                                                                                                |

|                           |                                                                                                                                                                                                                                      |
|---------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-06                                                                                                                                                                                                                             |
| <b>Threat title</b>       | Internal Overload DoS attack targeted at SMO functions or SMO services                                                                                                                                                               |
| <b>Threat description</b> | Overload situation could appear in the case of DoS attack or increased traffic on internal SMO interfaces. Inability to mitigate traffic volumetric attacks on an external interface affects availability of SMO data and functions. |
| <b>Threat type</b>        | Denial of Service                                                                                                                                                                                                                    |
| <b>Impact type</b>        | Availability                                                                                                                                                                                                                         |
| <b>Affected Asset</b>     | SMO                                                                                                                                                                                                                                  |

|                           |                                                                                                                                                                                                                                                                    |
|---------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-07                                                                                                                                                                                                                                                           |
| <b>Threat title</b>       | Internal DoS attack disables internal SMO function(s), SMO (service(s), or SMO process(es)                                                                                                                                                                         |
| <b>Threat description</b> | Internal malicious actor exploits a vulnerability or escalates privilege to execute a DoS attack by disabling one or more SMO processes, services, or functions. Inability to detect and report such events affects availability of SMO functions or SMO services. |
| <b>Threat type</b>        | Denial of Service, Escalation of Privilege                                                                                                                                                                                                                         |
| <b>Impact type</b>        | Availability                                                                                                                                                                                                                                                       |

|                       |     |
|-----------------------|-----|
| <b>Affected Asset</b> | SMO |
|-----------------------|-----|

|                           |                                                                                                                                |
|---------------------------|--------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-08                                                                                                                       |
| <b>Threat title</b>       | Attacker exploits insecure API to gain access to SMO                                                                           |
| <b>Threat description</b> | An insecure API may allow access to a system for an attacker to conduct remote code execution or an advanced persistent threat |
| <b>Threat type</b>        | Tampering, Information Disclosure, Escalation of Privilege                                                                     |
| <b>Impact type</b>        | Integrity, Confidentiality, Authorization                                                                                      |
| <b>Affected Asset</b>     | SMO                                                                                                                            |

|                           |                                                                                                                      |
|---------------------------|----------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-09                                                                                                             |
| <b>Threat title</b>       | Sensitive data in motion is exposed to an internal attacker                                                          |
| <b>Threat description</b> | Unprotected data transferred between internal SMO functions or SMO Services is disclosed to an internal threat actor |
| <b>Threat type</b>        | Information Disclosure                                                                                               |
| <b>Impact type</b>        | Confidentiality                                                                                                      |
| <b>Affected Asset</b>     | SMO                                                                                                                  |

|                           |                                                                                                                                          |
|---------------------------|------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-10                                                                                                                                 |
| <b>Threat title</b>       | Sensitive data at rest is exposed to an internal attacker                                                                                |
| <b>Threat description</b> | Unprotected data stored on the SMO is disclosed to an internal threat actor that has gain authorized access through privilege escalation |
| <b>Threat type</b>        | Information Disclosure                                                                                                                   |
| <b>Impact type</b>        | Confidentiality                                                                                                                          |
| <b>Affected Asset</b>     | SMO                                                                                                                                      |

|                           |                                                                                                                                                |
|---------------------------|------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-11                                                                                                                                       |
| <b>Threat title</b>       | AI/ML poisoning by internal attacker                                                                                                           |
| <b>Threat description</b> | Internal attacker gains authorized access exploited to poison AI/ML training data or the AI/ML models stored in the SMO to influence insights. |
| <b>Threat type</b>        | Tampering                                                                                                                                      |
| <b>Impact type</b>        | Integrity                                                                                                                                      |
| <b>Affected Asset</b>     | SMO                                                                                                                                            |

|                     |                                   |
|---------------------|-----------------------------------|
| <b>Threat ID</b>    | T-SMO-12                          |
| <b>Threat title</b> | AI/ML exposure on external entity |

|                           |                                                                                                                                                                                                                               |
|---------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat description</b> | An external attacker can gain access to external entities to view or modify sensitive data AI/ML data, or models, transferred between the external function and SMO via external interfaces (e.g., EI, Human-Machine, A1, O1) |
| <b>Threat type</b>        | Information disclosure, Tampering                                                                                                                                                                                             |
| <b>Impact type</b>        | Confidentiality, Integrity                                                                                                                                                                                                    |
| <b>Affected Asset</b>     | SMO                                                                                                                                                                                                                           |

|                           |                                                                                                                                |
|---------------------------|--------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-13                                                                                                                       |
| <b>Threat title</b>       | Malicious actor views local logs                                                                                               |
| <b>Threat description</b> | Malicious actor accesses locally stored logs in the SMO to perform reconnaissance to collect sensitive or private information. |
| <b>Threat type</b>        | Information disclosure                                                                                                         |
| <b>Impact type</b>        | Confidentiality                                                                                                                |
| <b>Affected Asset</b>     | SMO                                                                                                                            |

|                           |                                                                                                                |
|---------------------------|----------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-14                                                                                                       |
| <b>Threat title</b>       | Malicious actor modifies local log entries                                                                     |
| <b>Threat description</b> | Malicious actor accesses locally stored logs in the SMO to modify entries to hide presence or cause confusion. |
| <b>Threat type</b>        | Tampering                                                                                                      |
| <b>Impact type</b>        | Integrity                                                                                                      |
| <b>Affected Asset</b>     | SMO                                                                                                            |

|                           |                                                                                                                |
|---------------------------|----------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-15                                                                                                       |
| <b>Threat title</b>       | Malicious actor deletes local log entries                                                                      |
| <b>Threat description</b> | Malicious actor accesses locally stored logs in the SMO to delete entries to hide presence or cause confusion. |
| <b>Threat type</b>        | Tampering                                                                                                      |
| <b>Impact type</b>        | Integrity                                                                                                      |
| <b>Affected Asset</b>     | SMO                                                                                                            |

|                           |                                                                                                                                                            |
|---------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-16                                                                                                                                                   |
| <b>Threat title</b>       | Malicious actor intercepts exports of local logs                                                                                                           |
| <b>Threat description</b> | Malicious actor gains access to an external interface to intercept data in motion as logs are transferred from the SMO to a remote server/external entity. |
| <b>Threat type</b>        | Information disclosure                                                                                                                                     |
| <b>Impact type</b>        | Confidentiality                                                                                                                                            |
| <b>Affected Asset</b>     | SMO                                                                                                                                                        |

|                           |                                                                                               |
|---------------------------|-----------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-17                                                                                      |
| <b>Threat title</b>       | Malicious external actor gains unauthorized access to logs                                    |
| <b>Threat description</b> | Malicious external actor gains unauthorized access to stored logs to view, modify, and delete |
| <b>Threat type</b>        | Elevation of Privilege                                                                        |
| <b>Impact type</b>        | Confidentiality                                                                               |
| <b>Affected Asset</b>     | SMO                                                                                           |

|                           |                                                                                              |
|---------------------------|----------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-18                                                                                     |
| <b>Threat title</b>       | Malicious internal actor gains authorized access to logs                                     |
| <b>Threat description</b> | Malicious internal actor gains authorized access to stored logs to view, modify, and delete. |
| <b>Threat type</b>        | Elevation of Privilege                                                                       |
| <b>Impact type</b>        | Authorization                                                                                |
| <b>Affected Asset</b>     | SMO                                                                                          |

## 6.2 Threats at O2 interface

|                           |                                                                                                                                                     |
|---------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-19                                                                                                                                            |
| <b>Threat title</b>       | Internal attacker exploits O2 interface to view data in transit between SMO and O-Cloud                                                             |
| <b>Threat description</b> | If the O2 interface is not properly confidentiality protected, an internal attacker can perform a man-in-the-middle attack to view data in transit. |
| <b>Threat type</b>        | Information disclosure                                                                                                                              |
| <b>Impact type</b>        | Confidentiality                                                                                                                                     |
| <b>Affected Asset</b>     | O2 interface                                                                                                                                        |

|                           |                                                                                                                                                 |
|---------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-20                                                                                                                                        |
| <b>Threat title</b>       | Internal attacker exploits O2 interface to modify data in transit between SMO and O-Cloud                                                       |
| <b>Threat description</b> | If the O2 interface is not properly integrity protected, an internal attacker can perform a man-in-the-middle attack to modify data in transit. |
| <b>Threat type</b>        | Tampering                                                                                                                                       |
| <b>Impact type</b>        | Integrity                                                                                                                                       |
| <b>Affected Asset</b>     | O2 interface                                                                                                                                    |

|                  |          |
|------------------|----------|
| <b>Threat ID</b> | T-SMO-21 |
|------------------|----------|

|                           |                                                                                                                                                                                             |
|---------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat title</b>       | Internal attacker uses O2 interface via SMO to exploit API vulnerability to gain access to O-Cloud infrastructure                                                                           |
| <b>Threat description</b> | If the O2 interface uses an API with a known vulnerability that is not properly protected or patched, an attacker can exploit it to gain access to the O-Cloud infrastructure from the SMO. |
| <b>Threat type</b>        | Spoofing                                                                                                                                                                                    |
| <b>Impact type</b>        | Authenticity                                                                                                                                                                                |
| <b>Affected Asset</b>     | O-Cloud                                                                                                                                                                                     |

|                           |                                                                                                                                                                                                                                                                          |
|---------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-22                                                                                                                                                                                                                                                                 |
| <b>Threat title</b>       | Internal attacker floods O2 interface via SMO to cause DDoS on O-Cloud infrastructure                                                                                                                                                                                    |
| <b>Threat description</b> | If the O2 interface is not protected, an internal attacker on the SMO can flood the O2 interface to overload the O-Cloud. This can prevent legitimate messages from reaching the O-Cloud or cause heavy processing at the O-Cloud, resulting in performance degradation. |
| <b>Threat type</b>        | Denial of Service                                                                                                                                                                                                                                                        |
| <b>Impact type</b>        | Availability                                                                                                                                                                                                                                                             |
| <b>Affected Asset</b>     | O-Cloud                                                                                                                                                                                                                                                                  |

|                           |                                                                                                                                                                                             |
|---------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-23                                                                                                                                                                                    |
| <b>Threat title</b>       | External attacker uses O2 interface via O-Cloud to exploit API vulnerability to gain access to SMO                                                                                          |
| <b>Threat description</b> | If the O2 interface uses an API with a known vulnerability that is not properly protected or patched, an attacker can exploit it to gain access to the SMO from the O-Cloud infrastructure. |
| <b>Threat type</b>        | Spoofing                                                                                                                                                                                    |
| <b>Impact type</b>        | Authenticity                                                                                                                                                                                |
| <b>Affected Asset</b>     | SMO                                                                                                                                                                                         |

|                           |                                                                                                                                                                                                                                                                                       |
|---------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-24                                                                                                                                                                                                                                                                              |
| <b>Threat title</b>       | External attacker floods O2 interface via O-Cloud to cause DDoS on SMO                                                                                                                                                                                                                |
| <b>Threat description</b> | If the O2 interface is not protected, an external attacker in the O-Cloud can flood the O2 interface to overload the SMO. This can prevent legitimate messages from reaching the SMO or cause heavy processing at the SMO, resulting in performance degradation or outage of the SMO. |
| <b>Threat type</b>        | Denial of Service                                                                                                                                                                                                                                                                     |
| <b>Impact type</b>        | Availability                                                                                                                                                                                                                                                                          |
| <b>Affected Asset</b>     | SMO                                                                                                                                                                                                                                                                                   |

|                           |                                                                                                                                                      |
|---------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-25                                                                                                                                             |
| <b>Threat title</b>       | External attacker uses O2 interface via O-Cloud to gain authorized access to sensitive data-at-rest at the SMO                                       |
| <b>Threat description</b> | If the SMO is not protected, an external attacker at the O-Cloud can use the O2 interface to gain authorized access to the SMO to view data-at-rest. |
| <b>Threat type</b>        | Elevation of Privilege                                                                                                                               |

|                       |               |
|-----------------------|---------------|
| <b>Impact type</b>    | Authorization |
| <b>Affected Asset</b> | SMO           |

## 6.3 Threats at External interfaces

|                           |                                                                                                                                                          |
|---------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-26                                                                                                                                                 |
| <b>Threat title</b>       | External attacker exploits External interface to view data in transit between SMO and external service                                                   |
| <b>Threat description</b> | If an External interface is not properly confidentiality protected, an external attacker can perform a man-in-the-middle attack to view data in transit. |
| <b>Threat type</b>        | Information disclosure                                                                                                                                   |
| <b>Impact type</b>        | Confidentiality                                                                                                                                          |
| <b>Affected Asset</b>     | External interface                                                                                                                                       |

|                           |                                                                                                                                                      |
|---------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-27                                                                                                                                             |
| <b>Threat title</b>       | External attacker exploits External interface to modify data in transit between SMO and external service                                             |
| <b>Threat description</b> | If an External interface is not properly integrity protected, an external attacker can perform a man-in-the-middle attack to modify data in transit. |
| <b>Threat type</b>        | Tampering                                                                                                                                            |
| <b>Impact type</b>        | Integrity                                                                                                                                            |
| <b>Affected Asset</b>     | External interface                                                                                                                                   |

|                           |                                                                                                                                                                  |
|---------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-28                                                                                                                                                         |
| <b>Threat title</b>       | External attacker uses External interface to exploit API vulnerability to gain access to SMO                                                                     |
| <b>Threat description</b> | If an External interface uses an API with a known vulnerability that is not properly protected or patched, an attacker can exploit it to gain access to the SMO. |
| <b>Threat type</b>        | Spoofing                                                                                                                                                         |
| <b>Impact type</b>        | Authenticity                                                                                                                                                     |
| <b>Affected Asset</b>     | SMO                                                                                                                                                              |

|                           |                                                                                                                                                                                                                                                                                            |
|---------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-29                                                                                                                                                                                                                                                                                   |
| <b>Threat title</b>       | External attacker floods External interface to cause DDoS at SMO                                                                                                                                                                                                                           |
| <b>Threat description</b> | If the External interface is not protected, an external attacker can flood an External interface to overload the SMO. This can prevent legitimate messages and data from reaching the SMO or cause heavy processing at the SMO, resulting in performance degradation or outage of the SMO. |
| <b>Threat type</b>        | Denial of Service                                                                                                                                                                                                                                                                          |

|                       |              |
|-----------------------|--------------|
| <b>Impact type</b>    | Availability |
| <b>Affected Asset</b> | SMO          |

|                           |                                                                                                                                             |
|---------------------------|---------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-30                                                                                                                                    |
| <b>Threat title</b>       | External attacker uses External interface to gain access to sensitive data-at-rest at the SMO                                               |
| <b>Threat description</b> | If the SMO is not protected, an external attacker can use the External interface to gain authorized access to the SMO to view data-at-rest. |
| <b>Threat type</b>        | Elevation of Privilege                                                                                                                      |
| <b>Impact type</b>        | Authorization                                                                                                                               |
| <b>Affected Asset</b>     | SMO                                                                                                                                         |

|                           |                                                                                                                                                                                                                                                                                                                                                            |
|---------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-31                                                                                                                                                                                                                                                                                                                                                   |
| <b>Threat title</b>       | External attacker poisons External AI/ML data to corrupt SMO                                                                                                                                                                                                                                                                                               |
| <b>Threat description</b> | External data sources may be outside the control of the stakeholder(s) responsible for the O-RAN deployment. The stakeholder for an External data source could fail to provide proper security controls to protect data consumed by the SMO. If an external attacker were to gain access to AI/ML data, it could be corrupted and then be used at the SMO. |
| <b>Threat type</b>        | Tampering                                                                                                                                                                                                                                                                                                                                                  |
| <b>Impact type</b>        | Integrity                                                                                                                                                                                                                                                                                                                                                  |
| <b>Affected Asset</b>     | SMO                                                                                                                                                                                                                                                                                                                                                        |

|                           |                                                                                                                                                                                                                                                                                                                                                                                 |
|---------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-32                                                                                                                                                                                                                                                                                                                                                                        |
| <b>Threat title</b>       | External attacker poisons External Enrichment Information data sources to corrupt SMO                                                                                                                                                                                                                                                                                           |
| <b>Threat description</b> | External data sources may be outside the control of the stakeholder(s) responsible for the O-RAN deployment. The stakeholder for an External data source could fail to provide proper security controls to protect data consumed by the SMO. If an external attacker were to gain access to External Enrichment Information, it could be corrupted and then be used at the SMO. |
| <b>Threat type</b>        | Tampering                                                                                                                                                                                                                                                                                                                                                                       |
| <b>Impact type</b>        | Integrity                                                                                                                                                                                                                                                                                                                                                                       |
| <b>Affected Asset</b>     | SMO                                                                                                                                                                                                                                                                                                                                                                             |

## 6.4 Threats Targeting SME

|                           |                                                                                                                                                                               |
|---------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-33                                                                                                                                                                      |
| <b>Threat title</b>       | rApp floods SME                                                                                                                                                               |
| <b>Threat description</b> | Misbehaving 3rd-party rApp, maliciously or non-maliciously, floods internal SMOS Communication interface targeting the SME to bring a volumetric DDoS attack against the SMO. |
| <b>Threat type</b>        | Denial of Service                                                                                                                                                             |

|                       |              |
|-----------------------|--------------|
| <b>Impact type</b>    | Availability |
| <b>Affected Asset</b> | SMO, SME     |

|                           |                                                                                                                                                     |
|---------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-34                                                                                                                                            |
| <b>Threat title</b>       | External Consumer floods SME                                                                                                                        |
| <b>Threat description</b> | External Source, maliciously or non-maliciously, floods the External interface targeting the SME to bring a volumetric DDoS attack against the SMO. |
| <b>Threat type</b>        | Denial of Service                                                                                                                                   |
| <b>Impact type</b>        | Availability                                                                                                                                        |
| <b>Affected Asset</b>     | SMO, SME                                                                                                                                            |

|                           |                                                                                                                                          |
|---------------------------|------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-35                                                                                                                                 |
| <b>Threat title</b>       | SMOS floods SME                                                                                                                          |
| <b>Threat description</b> | SMOS, maliciously or non-maliciously, floods the SMOS Communication targeting the SME to bring a volumetric DDoS attack against the SMO. |
| <b>Threat type</b>        | Denial of Service                                                                                                                        |
| <b>Impact type</b>        | Availability                                                                                                                             |
| <b>Affected Asset</b>     | SMO, SMOS, SME                                                                                                                           |

## 6.5 Preliminary Threat Analysis for RAN-Core Data Sharing

RAN-Core Data Sharing is a new SMO feature to provide data export from the SMO to the 5G Core (5GC). 5 possible architectural options are being considered:

- Option 1: SMO/Non-RT RIC to 5GC Consumer with Facade of NWDAF
- Option 2: SMO/Non-RT RIC to 5GC DCCF/MFAF with Facade of NWDAF
- Option 3: SMO/Non-RT RIC to 5GC NWDAF with Facade of OA&M
- Option 4: SMO/Non-RT RIC to 5GC NWDAF with Facade of RAN NF
- Option 5: SMO/Non-RT RIC to 5GC NWDAF with MDAS through SME

WG11 performed a security analysis of the architectural options to provide recommendations for which should be considered for specification. In summary, Option 1 is high security risk and should not be considered. Option 2, 3, 4, and 5 are lower risk and equivalent from a security perspective. However, those options have a major risk due to lack of certificate-based mutual authentication with NWDAF. Option 5, in addition, requires the 3GPP NWDAF add support for the O-RAN SME interface, which needs new 3GPP standardization.

## 6.6 Threats Targeting DME

|                           |                                                                                                                                                                               |
|---------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-36                                                                                                                                                                      |
| <b>Threat title</b>       | rApp floods DME                                                                                                                                                               |
| <b>Threat description</b> | Misbehaving 3rd-party rApp, maliciously or non-maliciously, floods internal SMOS Communication interface targeting the DME to bring a volumetric DDoS attack against the SMO. |
| <b>Threat type</b>        | Denial of Service                                                                                                                                                             |
| <b>Impact type</b>        | Availability                                                                                                                                                                  |
| <b>Affected Asset</b>     | SMO, DME                                                                                                                                                                      |

|                           |                                                                                                                                                     |
|---------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-37                                                                                                                                            |
| <b>Threat title</b>       | External Consumer floods DME                                                                                                                        |
| <b>Threat description</b> | External Source, maliciously or non-maliciously, floods the External interface targeting the DME to bring a volumetric DDoS attack against the SMO. |
| <b>Threat type</b>        | Denial of Service                                                                                                                                   |
| <b>Impact type</b>        | Availability                                                                                                                                        |
| <b>Affected Asset</b>     | SMO, DME                                                                                                                                            |

|                           |                                                                                                                                          |
|---------------------------|------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Threat ID</b>          | T-SMO-38                                                                                                                                 |
| <b>Threat title</b>       | SMOS floods DME                                                                                                                          |
| <b>Threat description</b> | SMOS, maliciously or non-maliciously, floods the SMOS Communication targeting the DME to bring a volumetric DDoS attack against the SMO. |
| <b>Threat type</b>        | Denial of Service                                                                                                                        |
| <b>Impact type</b>        | Availability                                                                                                                             |
| <b>Affected Asset</b>     | SMO, SMOS, DME                                                                                                                           |

## 7 Security Controls

---

Industry recommendations for strong security controls are provided from sources such as the OWASP Top 10 Proactive Controls [i.15], Center for Internet Security (CIS) Critical Security Controls [i.16], Cloud Security Alliance (CSA) Cloud Control Matrix (CCM) [i.17], ISO/IEC 27001:2013 Information Security Management System (ISMS) [i.18], NIST SP 800-53r5 Security and Privacy Controls for Information Systems and Organizations [i.19], and Cybersecurity and Infrastructure Security Agency (CISA) Security Guidance for 5G Cloud Infrastructures [i.9].

The OWASP Top 10 Proactive Controls are as follow:

- C1: Define Security Requirements
- C2: Leverage Security Frameworks and Libraries
- C3: Secure Database Access
- C4: Encode and Escape Data
- C5: Validate All Inputs
- C6: Implement Digital Identity
- C7: Enforce Access Controls
- C8: Protect Data Everywhere
- C9: Implement Security Logging and Monitoring
- C10: Handle All Errors and Exceptions

The CIS Critical Security Controls are as follow:

- CIS Control 1: Inventory and Control of Enterprise Assets
- CIS Control 2: Inventory and Control of Software Assets
- CIS Control 3: Data Protection
- CIS Control 4: Secure Configuration of Enterprise Assets and Software
- CIS Control 5: Account Management
- CIS Control 6: Access Control Management
- CIS Control 7: Continuous Vulnerability Management
- CIS Control 8: Audit Log Management
- CIS Control 9: Email Web Browser and Protections
- CIS Control 10: Malware Defenses
- CIS Control 11: Data Recovery
- CIS Control 12: Network Infrastructure Management
- CIS Control 13: Network Monitoring and Defense
- CIS Control 14: Security Awareness and Skills Training
- CIS Control 15: Service Provider Management
- CIS Control 16: Application Software Security
- CIS Control 17: Incident Response Management

## CIS Control 18: Penetration Testing

Relevant controls from the CSA CCM are 2. Application and Interface Security, 5. Cryptography, Encryption, and Key Management, 7. Data Security and Privacy Lifecycle Management, and 10. Identity and Access Management (IAM).

Relevant controls from ISO/IEC 27001:2013 are 5. Access Controls, 6. Cryptography, and 9. Communications Security.

Relevant controls from NIST SP 800-53r5 are 1. Access Controls, 16. Risk Assessment, 18. System and Communications Protection, and 19. System and Information Integrity.

Relevant controls from CISA's Security Guidance are mTLS 1.2, or higher, with PKI and X.509 certificates, Multi-Factor Authentication (MFA), Principle of Least Privilege, Continuous Monitoring and Logging, and data confidentiality and protection as components of a zero trust architecture as defined in NIST SP 800-207 [i.8].

With consideration of these external sources, the following security controls should be evaluated for the SMO risk analysis:

Control-1: mTLS 1.2 or 1.3 with PKI and X.509 certificates

Control-2: OAuth 2.0

Control-3: IAM (using RBAC, ABAC, PBAC, TBAC)

Control-4: Principle of Least Privilege

Control-5: Certificate Management

Control-6: API Message Integrity Protection and Input Validation

Control-7: API Message Authentication

Control-8: Encryption for Data at Rest

Control-9: Encryption for Data in Motion

Control-10: Integrity Protection for Data at Rest

Control-11: Integrity Protection for Data in Motion

Control-12: Integrity Protection for Data in Use

Control-13: Digital Signatures

Control-14: Monitoring and Logging

Control-15: Alerting

Control-16: Rate-Limiting

Control-17: Configuration Validation

Control-18: Network Segmentation and Traffic Filtering

## 8 Risk Assessment

This section provides risk assessment tables for each of the identified assets. These tables list the assets, threats, impacts, and possible security controls.

A malicious actor may be a nation-state adversary, cybercriminal, or employee. In a ZTA, perimeter defenses alone are insufficient. The SMO must be protected from untrusted external sources attempting to have access, while also assuming internal threat actors are inside the network with access to its functions and data. Security controls for a ZTA, protecting against external and internal threats, should be implemented through a risk-based approach. A risk analysis calculates risk levels by assessing the threat's Likelihood of attack and the Impact from the attack.

Impact scores can be lowered with consideration of existing security controls. Impact scoring is based upon current security controls. Impact scoring does not consider security controls that may be potentially specified in the future.

Likelihood scores may be higher when the goal is a ZTA, because external and internal threats must be considered. When likelihood scoring during a risk analysis, it is necessary to consider internal threats performing reconnaissance attacks impacting confidentiality and privacy and attacks causing damage or degrading performance impacting availability. Internal threat actors are less likely to perform damaging attacks that are quickly and easily detected and blocked, but more likely to attempt reconnaissance attacks to collect information. As a result, reconnaissance type attacks can be scored Likelihood = High while damaging/availability attacks can be scored Likelihood = Medium or Low.

External and internal threats are from the perspective of the SMO. External Threats are external to the SMO and Internal Threats are internal to the SMO. An External Threat may be external to the SMO but internal to the O-RAN architecture.

A risk analysis of SMO threats is provided in the tables below covering general SMO risks, risks to the O2 interface, and risks to External interfaces.

Threats and risks to the A1 and R1 interfaces are assessed in a separate Technical Report, Study on Security for Non-RT-RIC [i.20].

Additional SMO threats may be added for Decoupled SMO and Shared O-RU.

### 8.1 General SMO Risks

Table 8-1. SMO Risk Analysis

| Asset-Id   | Asset Name | Threat-Id | Threat Description (Brief)                                           | Impact/<br>Likelihood<br>Raw Score   | Possible Security Controls                   | Security Control-id             |
|------------|------------|-----------|----------------------------------------------------------------------|--------------------------------------|----------------------------------------------|---------------------------------|
| ASSET-C-01 | SMO        | T-SMO-01  | External attacker exploits authentication weakness on SMO            | Impact = High<br>Likelihood = Medium | Data encryption using mTLS 1.2 or 1.3        | Control-1                       |
| ASSET-C-01 | SMO        | T-SMO-02  | External attacker exploits authorization weakness on SMO             | Impact = High<br>Likelihood = Medium | OAuth 2.0, IAM, principle of least privilege | Control-2, Control-3, Control-4 |
| ASSET-C-01 | SMO        | T-SMO-03  | External Overload DoS attack targeted at SMO                         | Impact = High<br>Likelihood = Medium | Rate-Limiting                                | Control-16                      |
| ASSET-C-01 | SMO        | T-SMO-04  | Internal attacker exploits authentication weakness on a SMO function | Impact = High<br>Likelihood = Medium | Data encryption using mTLS 1.2 or 1.3        | Control-1                       |
| ASSET-C-01 | SMO        | T-SMO-05  | Internal attacker exploits authorization weakness on SMO             | Impact = High<br>Likelihood = Medium | OAuth 2.0, IAM, principle of least privilege | Control-2, Control-3            |
| ASSET-C-01 | SMO        | T-SMO-06  | Internal Overload DoS attack targeted at SMO functions               | Impact = High                        | Rate-Limiting                                | Control-16                      |

|            |     |          |                                                                      |                                      |                                                                |                                  |
|------------|-----|----------|----------------------------------------------------------------------|--------------------------------------|----------------------------------------------------------------|----------------------------------|
|            |     |          |                                                                      | Likelihood = Medium                  |                                                                |                                  |
| ASSET-C-01 | SMO | T-SMO-07 | Internal DoS attack disables internal SMO function(s) or process(es) | Impact = High<br>Likelihood = Medium | Monitoring, Logging, Alerting                                  | Control-14, Control-15           |
| ASSET-C-01 | SMO | T-SMO-08 | Attacker exploits insecure API to gain access to SMO                 | Impact = High<br>Likelihood = Medium | API input validation                                           | Control-6                        |
| ASSET-C-01 | SMO | T-SMO-09 | Sensitive data in motion is exposed to an internal attacker          | Impact = High<br>Likelihood = Medium | Data encryption and integrity protection using mTLS 1.2 or 1.3 | Control-1                        |
| ASSET-C-01 | SMO | T-SMO-10 | Sensitive data at rest is exposed to an internal attacker            | Impact = High<br>Likelihood = High   | Data encryption and integrity protection                       | Control-8, Control-10            |
| ASSET-C-01 | SMO | T-SMO-11 | AI/ML poisoning by internal attacker                                 | Impact = High<br>Likelihood = Medium | Integrity protection                                           | Control-10                       |
| ASSET-C-01 | SMO | T-SMO-12 | AI/ML exposure on external entity                                    | Impact = High<br>Likelihood = Medium | Data encryption, Integrity protection, API input validation    | Control-6, Control-8, Control-10 |
| ASSET-C-01 | SMO | T-SMO-13 | Malicious actor views local logs                                     | Impact = High<br>Likelihood = High   | Data encryption                                                | Control-8                        |
| ASSET-C-01 | SMO | T-SMO-14 | Malicious actor modifies local log entries                           | Impact = High<br>Likelihood = Medium | Integrity protection                                           | Control-10                       |
| ASSET-C-01 | SMO | T-SMO-15 | Malicious actor deletes local logs                                   | Impact = High<br>Likelihood = Medium | Integrity protection                                           | Control-10                       |
| ASSET-C-01 | SMO | T-SMO-16 | Malicious actor intercepts exports of local logs                     | Impact = High<br>Likelihood = High   | Data encryption                                                | Control-9                        |
| ASSET-C-01 | SMO | T-SMO-17 | Malicious external actor gains unauthorized access to logs           | Impact = High<br>Likelihood = High   | IAM, principle of least privilege                              | Control-3, Control-4             |
| ASSET-C-01 | SMO | T-SMO-18 | Malicious internal actor gains authorized access to logs             | Impact = High<br>Likelihood = High   | Data encryption                                                | Control-8                        |

## 8.2 Threats at O2 interface

Table 8-2. SMO Risk Analysis for Internal Threats at O2 Interface

| Asset-Id   | Asset Name | Threat-Id | Threat Description (Brief)                                                                | Impact/<br>Likelihood<br>Raw Score   | Possible Security Controls                 | Security Control-id |
|------------|------------|-----------|-------------------------------------------------------------------------------------------|--------------------------------------|--------------------------------------------|---------------------|
| ASSET-C-01 | SMO        | T-SMO-19  | Internal attacker exploits O2 interface to view data in transit between SMO and O-Cloud   | Impact = High<br>Likelihood = High   | Data encryption using mTLS 1.2 or 1.3      | Control-1           |
| ASSET-C-01 | SMO        | T-SMO-20  | Internal attacker exploits O2 interface to modify data in transit between SMO and O-Cloud | Impact = High<br>Likelihood = Medium | Integrity protection using mTLS 1.2 or 1.3 | Control-1           |

|            |     |          |                                                                                                                   |                                      |                                                  |                        |
|------------|-----|----------|-------------------------------------------------------------------------------------------------------------------|--------------------------------------|--------------------------------------------------|------------------------|
| ASSET-C-01 | SMO | T-SMO-21 | Internal attacker uses O2 interface via SMO to exploit API vulnerability to gain access to O-Cloud infrastructure | Impact = High<br>Likelihood = High   | API message authentication, API input validation | Control-7, Control-6   |
| ASSET-C-01 | SMO | T-SMO-22 | Internal attacker floods O2 interface via SMO to cause DDoS on O-Cloud infrastructure                             | Impact = High<br>Likelihood = Medium | Rate-Limiting, Network segmentation              | Control-16, Control-18 |
| ASSET-C-01 | SMO | T-SMO-23 | External attacker uses O2 interface via O-Cloud to exploit API vulnerability to gain access to SMO                | Impact = High<br>Likelihood = Medium | API message authentication, API input validation | Control-7, Control-6   |
| ASSET-C-01 | SMO | T-SMO-24 | External attacker floods O2 interface via O-Cloud to cause DDoS on SMO                                            | Impact = High<br>Likelihood = Medium | Rate-Limiting, Network segmentation              | Control-16, Control-18 |
| ASSET-C-01 | SMO | T-SMO-25 | External attacker uses O2 interface via O-Cloud to gain authorized access to sensitive data-at-rest at the SMO    | Impact = High<br>Likelihood = Medium | Data encryption, Integrity protection            | Control-8, Control-10  |

## 8.3 Threats at External Interfaces

Table 8-3. SMO Risk Analysis for External Threats at External interfaces

| Asset-Id   | Asset Name | Threat-Id | Threat Description (Brief)                                                                               | Impact/<br>Likelihood<br>Raw Score   | Possible Security Controls                       | Security Control-id    |
|------------|------------|-----------|----------------------------------------------------------------------------------------------------------|--------------------------------------|--------------------------------------------------|------------------------|
| ASSET-C-01 | SMO        | T-SMO-26  | External attacker exploits External interface to view data in transit between SMO and external service   | Impact = High<br>Likelihood = High   | Data encryption using mTLS 1.2 or 1.3            | Control-1              |
| ASSET-C-01 | SMO        | T-SMO-27  | External attacker exploits External interface to modify data in transit between SMO and external service | Impact = High<br>Likelihood = Medium | Integrity protection using mTLS 1.2 or 1.3       | Control-1              |
| ASSET-C-01 | SMO        | T-SMO-28  | External attacker uses External interface to exploit API vulnerability to gain access to SMO             | Impact = High<br>Likelihood = Medium | API message authentication, API input validation | Control-7, Control-6   |
| ASSET-C-01 | SMO        | T-SMO-29  | External attacker floods External interface to cause DDoS at SMO                                         | Impact = High<br>Likelihood = Medium | Rate-Limiting, Network segmentation              | Control-16, Control-18 |
| ASSET-C-01 | SMO        | T-SMO-30  | External attacker uses External interface to gain access to sensitive data-at-rest at the SMO            | Impact = High<br>Likelihood = Medium | Data encryption, Integrity protection            | Control-8, Control-10  |
| ASSET-C-01 | SMO        | T-SMO-31  | External attacker poisons External AI/ML data to corrupt SMO                                             | Impact = High<br>Likelihood = High   | Data encryption, Integrity protection            | Control-8, Control-10  |
| ASSET-C-01 | SMO        | T-SMO-32  | External attacker poisons External Enrichment Information data sources to corrupt SMO                    | Impact = High<br>Likelihood = High   | Data encryption, Integrity protection            | Control-8, Control-10  |

## 8.4 Threats Targeting SME

Table 8-4. SMO Risk Analysis for Threats Targeting SME

| Asset-Id | Asset Name | Threat-Id | Threat Description (Brief)   | Impact/<br>Likelihood<br>Raw Score   | Possible Security Controls                             | Security Control-id    |
|----------|------------|-----------|------------------------------|--------------------------------------|--------------------------------------------------------|------------------------|
| TBD      | SME        | T-SMO-32  | rApp floods SME              | Impact = High<br>Likelihood = Medium | Overload protection with rate-limiting at SME          | Control-16             |
| TBD      | SME        | T-SMO-33  | External Consumer floods SME | Impact = High<br>Likelihood = Medium | Network Segmentation, Traffic Filtering, Rate-Limiting | Control-16, Control-18 |

## 9 Primary Security Issues

The following items were identified during the SMO Security Analysis phase 1 and were addressed in TR v1:

1. External interfaces to the SMO and Non-RT RIC have risks of exploitation from external threat actors. The protocol and API used on an external interface is defined by the application or service and is not in-scope for the O-RAN Alliance. WG11 analyzed the threats, risks, and potential security controls with the goal to provide general security requirements for any implementation of an External interface with the goal to protect O-RAN network functions and data.
2. The O2 interface is at risk of being exploited by an internal threat actor at the SMO or the O-Cloud. This TR provides a security analysis of the O2 interface from the perspectives of the internal threat actor at the SMO and the O-Cloud, in addition to external threats. The work item team will need to collaborate with the O-Cloud security work item team to ensure complete coverage of O2 threats and security controls.

The following items were identified as SMO security topics that require additional phases of the SMO Security Analysis to produce an update to the TR.

1. WG1 is considering a Decoupled SMO architecture based upon a Service-based Architecture (SBA) as used in the 5G Core. This evolution of the SMO architecture would have security implications which WG1 should consider. WG11 has performed a security analysis for Decoupled SMO. WG11 should contribute security requirements as WG1 develops specifications for a Decoupled SMO.
2. The Decoupled SMO architecture will define a set of SMO Services called SMOS. WG11 has performed a security analysis for SMOS. WG11 should contribute security requirements as WG1 develops specifications for SMOS. Requirements can be general SMOS security requirements and SMOS-specific security requirements.
3. SMO service consumers and service producers may be SMOS and/or rApps. WG1 is considering to have the Service Management Exposure (SME) service act a security proxy for all SMO service consumers access service producers. WG11 should perform a security analysis for the SME to be a security proxy.
4. WG11 has performed a security analysis for RAN-Core Data Sharing. WG11 should contribute security requirements as WG1 develops specifications for RAN-Core Data Sharing.

# 10 Recommendations

The Security Analysis presented in this technical report used the following process:

1. Asset identification -> 2. Threat identification -> 3. Threat analysis -> 4. Risk analysis -> 5. Recommend Security Controls

The SMO is a logical framework, not an implementation architecture, with external interfaces and internal functions and interfaces that are assets which should be protected with security controls. The SMO may be implemented as a monolithic platform or multiple disaggregated functions, such as SMO functions and Non-RT-RIC functions, which should be protected assets. Other SMO assets are the R1, A1, O1, O2, OFH M-Plane, and External interfaces and data at rest and in transit.

**Recommendation 1:** WG11 should update the Security Threat Modeling and Remediation Analysis document [i.6] to include the assets identified in this security analysis technical report. A CR will be generated.

For the threat analysis, external and internal threats were considered from the perspective of the SMO. Internal threats are internal the SMO and external threats are external to the SMO. External threats may be external to the SMO and internal to the O-RAN architecture. More than 30 threats were identified, categorized as general SMO threats, O2 interface threats, and External interfaces threat.

**Recommendation 2:** WG11 should update the Security Threat Modeling and Remediation Analysis document [i.6] to include the threats and threat tables created in this security analysis technical report. A CR will be generated.

Risk analysis of the identified threats included impact-likelihood scoring. All 30+ of the identified threats were score either high-medium or high-high. External data sources are considered the greatest threat to the SMO due to the risk of an external threat actor poisoning external data that is imported into the SMO and the risk of an external threat actor exploiting an API on the external interface to gain access to the SMO or perform a remote code execution attack.

Likelihood scoring was influenced by the consideration of a zero trust architecture (ZTA), which is a publicly expressed goal of the O-RAN Alliance to consider external and internal threats. ZTA is built on the foundational principles that perimeter defenses are insufficient to secure a network as internal external threats pose risk to a network. There are two guidelines for designing a network and its network functions for a ZTA:

1. There is no implicit trust granted to an asset based upon ownership, physical location, or network location [i.8].
2. Assume the adversary is already inside the network [i.9].

The security controls recommended in this TR protect the SMO from confidentiality, integrity, and availability attacks from external and internal threats, consistent with a ZTA.

**Recommendation 3:** The SMO should have security controls implemented to protect its functions and interfaces from external and internal threats, consistent with a ZTA. Specific requirements will be formed as this work item continues. A CR for the WG11 Security Requirements Specifications is planned for the March release train.

Consistent with a ZTA, the SMO should be secure by design in which its security posture does not assume that the SMO internal functions and interfaces are secure.

**Recommendation 4:** WG11 should collaborate with WG1 to ensure the WG11 security specifications are referenced by WG1 in its SMO specifications. This process will build-in security to the evolving specifications for the SMO and Decoupled SMO.

The SMO architecture is continuing to evolve to support Decoupled SMO and direct communication between internal SMO functions and applications. In addition, the security analysis will also need to consider Transport Node (TN) Termination, as specified in WG9, and Cooperative Transport Interface (CTI), as specified in WG4.

**Recommendation 5:** This SMO Security work item continues its security analysis to produce a TR v2 for the March release train, addressing Decoupled SMO, TN, and CTI.

The SMO role in certificate management is currently unspecified.

**Recommendation 6:** The WG11 Certificate Management work item team should investigate a potential role, if any, for the SMO in certificate management.

## Annex: Change history/Change request (history)

| Date          | Revision  | Doc status      | Author | Description                                                               |
|---------------|-----------|-----------------|--------|---------------------------------------------------------------------------|
| July 2022     | V01.00.00 | First release   | WG11   | Document creation, template                                               |
| March 2023    | V02.00    | Second release  | WG11   | Update architecture diagrams in Section 2 – Assets.                       |
| November 2023 | V03.00    | Third release   | WG11   | Add security analysis for Decoupled SMO and RAN-Core Data Sharing         |
| March 2024    | V04.00    | Fourth release  | WG11   | Update Assets list for Decoupled SMO. Add security threats for the SME.   |
| July 2024     | V05.00    | Fifth release   | WG11   | Update Issues list. Update for SMO Services in Decoupled SMO architecture |
| November 2024 | V06.00    | Sixth release   | WG11   | Added asset-id's and acronyms                                             |
| July 2025     | V07.00    | Seventh release | WG11   | Added DME threat analysis<br>Format with approved TR template             |